

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☒	☐	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☒	☐	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☒	☐	Ensure data is properly classified and inventoried.

- | | | |
|-------------------------------------|--------------------------|---|
| ☒ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|-------------------------------------|--------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional):

ENCRYPTION OF DATA:

Implement an encryption system for customer credit card data both at rest in the database and in transit, for example you could use AWS KMS / Azure Key Vault to administrate native keys in the cloud.

Even if data maintains its integrity within the database, the lack of encryption violates GDPR requirements (specifically Article 32, 'Security of processing') and PCI DSS compliance. This exposure risks severe regulatory fines. Furthermore, in the event of a security breach, unencrypted data would be fully readable by threat actors.

PASSWORDS ENFORCEMENT:

Implement an enterprise password manager to centralize user credentials and minimize helpdesk downtime caused by lost passwords.

This solution can be deployed as an on-premise (local) system or via a commercial cloud service. If a commercial solution is selected, we highly recommend [Bitwarden](#) or [1Password](#).

Regarding security policies, I recommend increasing the length of the password to 12 or 15 characters. You can also implement a system notification that prompts users to update their credentials length.

AUTHORIZATION POLICIES:

Define clear access and control policies to determine who can have authorization to the client's database in order to maintain confidentiality and protection of client's personal information, and reduce the attack surface.

SEPARATE DUTIES:

Organize the corporate hierarchy and establish the duties, limits, and responsibilities for each position. You can start by setting up a schedule to ensure continuous monitoring of the legacy system, so personnel know how to maintain it in the event of a failure.

IDS INTEGRATION:

Having an IDS (Intrusion Detection System) as a part of the security operations is crucial to detect possible income threats and mitigate risks in the internal network and clients database, we strongly recommend to implement systems like Snort or Suricata.

BACKUPS:

Having several backups will help the business to quickly recover from an hypothetical security breach or a possible failure that may occur in the system, also it will minimize the loss of information. We recommend having two physical copies in the company, one of them in a computer without internet connection, a backup uploaded in the

cloud in reliable accounts and a copy uploaded in a server from another country or having a physical copy in a retired location from the business.

PLAYBOOK:

A playbook will serve as a step by step guide that explains how to respond to specific scenarios such as the procedures to respond against disasters and having the ability to recover and keep with the business continuity.